

RSA密码系统, RSA密码体制

共模攻击, 致盲攻击, 低私人指数攻击

⑥

300-312, 287

攻击 RSA 密码系统二十年 TN918.1

D. Boneh

Boneh, D

0157.4

1 引言

由 Ron Rivest, Adi Shamir 和 Len Adleman 提出的 RSA 密码系统, 首先在 1977 年 8 月份的《科学美国人》上发表. 这一密码系统被普遍用于保密和确保数字数据的可靠性. 目前许多商业系统使用 RSA. 它被用于万维网的服务器和浏览器以确保万维网的运行, 用于 e-mail 以提供保密和认证, 用于远程注册的安全. 并处于电子信用卡支付系统的中心. 简言之, RSA 常用于关心数字数据安全的地方.

自 RSA 系统发表以后, 许多研究人员自发地对它进行了分析. 尽管二十年的研究产生了许多诱人的攻击, 但它们之中没有一个是破坏性的. 这些攻击揭示了不正当使用 RSA 的危险. 事实上, 安全地使用 RSA 是一个非平凡的任务. 我们的目的是综述其中的一些攻击并描述攻击中所使用的数学工具. 在整个综述中我们依照用名惯例用 Alice 和 Bob 代表希望通信的双方. 用 Marvin 代表一个要窃听或篡改 Alice 和 Bob 之间通信的恶意攻击者.

我们现在描述一个简化的 RSA 加密. 设 $N = pq$, p, q 是两个规模相同的大素数 (每个 $n/2$ 比特**). N 的一个典型规模为 $N = 1024$ 比特, 即 309 十进制位. 每个因子为 512 比特. 设 e, d 是两个满足 $ed = 1 \pmod{\varphi(N)}$ 的整数, 这里 $\varphi(N) = (p-1)(q-1)$ 是乘法群 Z_N^* 的阶. 我们称 N 为 RSA 的模, e 为加密指数, d 为解密指数. 称数对 (N, e) 为公钥. 如它的名字所示, 公钥是公开的, 并用于加密消息. 数对 (N, d) 称为保密钥或私钥, 只有加密消息的接收者知道. 保密钥用于解密密文.

一 消息是一整数 $M, M \in Z_N^*$. 为加密 M , 计算 $C = M^e \pmod{N}$. 为解密密文, 合法的接收者计算 $C^d \pmod{N}$. 事实上,

$$C^d = M^{ed} = M \pmod{N},$$

原题: Twenty years of attacks on the RSA Cryptosystem, 译自: Notices of the AMS, Feb.(1999), 203-213.

**译者注: 称正整数 N 的规模为 n 比特, 或说 N 为 n 比特, 是指, 或, N 用二进制表示时, 需要 n 位.

最后一个等式由 Euler 定理得出. 定义 RSA 函数为 $x \mapsto x^e \bmod N$. 若给出 d , 由上面的等式, 很容易求函数的逆. 我们把 d 称作可以求 RSA 函数逆的陷门. 本综述研究在无陷门的情况下求 RSA 函数逆的困难性. 我们称之为攻破 RSA. 更精确些, 给定三元组 (N, e, C) , 我们问, 当 N 的分解未知时, 计算 C 模 $N = pq$ 的 e 次方根有多困难. 由于 Z_N^* 为有限集, 有人可能列举 Z_N^* 的元素, 直至 M 被发现. 但不幸的是, 这一算法所需时间的阶为 N , 即是输入规模的指数次, 输入规模的阶为 $\log_2 N$. 我们多半只对运行时间少的算法才有兴趣, 就是时间的阶为 n^c 的算法, 这里 $n = \log_2 N$, c 为小的常数 (比如说 $c < 5$). 这样的算法对实际中所遇到的问题中的输入, 常常执行得很好. 本文称这种算法为有效的.

相对于 RSA 密码体制, 本文主要研究 RSA 函数. 粗略地说, 对随机输入, RSA 函数求逆的困难性蕴含给定 (N, e, C) , 攻击者不可能恢复明文 M . 然而, 一个密码系统必须经受更精心策划的攻击. 若给定 (N, e, C) , 难以恢复关于 M 的任何信息, 这被称为语义安全 (Semantic Security). 在此我们不讨论这些精致的攻击. 上面描述的 RSA 不是语义安全的: 给定 (N, e, C) , 很容易得到关于明文 M 的一些信息, (例如, M 对 N 的 Jacobi 符号可以很容易地从 C 导出), 但 RSA 可以通过在加密过程中加入随机性而具有语义安全.

RSA 函数 $x \mapsto x^e \bmod N$ 是陷门单向函数的一个例子. 它可以简单计算, 但 (就我们所知) 除在特殊的环境下, 不知陷门 d 要求出函数的逆是困难的. 陷门单向函数可用于数字签名. 数字签名可提供合法文档的认证和不可抵赖性证明. 例如, 它们被用于签订数字支票和电子订单. 为用 RSA 签订信息 $M \in Z_N^*$, Alice 用她的私钥 (N, d) 于 M 并得到一个签名 $S = M^d \bmod N$. 给定 (M, S) , 任何人可以通过验证 $S^e = M \bmod N$ 来验证 Alice 的签名. 因为只有 Alice 能生成 S , 因此可以设想攻击者不能伪造 Alice 的签名. 不幸的是, 事情不是如此简单; 为了安全, 需要一些额外的措施. 数字签名是 RSA 的一个重要应用. 我们综述中的一些攻击集中于 RSA 的数字签名上.

生成一对 RSA 钥需要随机选取的两个 $n/2$ 比特的素数, 由它们的乘积得到 N . 然后, 对一给定的加密指数 $e < \varphi(N)$, 用扩展的 Euclid 算法计算 $d = e^{-1} \bmod \varphi(N)$. 由于素数的集合充分稠密, $n/2$ 比特的随机素数可通过随机连续选取 $n/2$ 比特的整数, 以及通过概率素性检测来检验每个数的素性而被很快地生成.

2 分解大整数

对 RSA 公钥 (N, e) 的第一个攻击是考虑分解模 N . 给出 N 的分解, 攻击者容易构造 $\varphi(N)$, 并由此得到解密指数 $d = e^{-1} \bmod \varphi(N)$. 我们称通过分解模来攻击 RSA 为蛮力攻击 (brute-force attack). 尽管分解算法持续改进, 它的最新结果对正常使用的 RSA 的安全性仍远未构成威胁. 分解大整数是计算数学中最美妙的问题之一, 但它不是本文的论题. 为完整起见, 我们注意到目前最快的分解算法是一般数域筛法. 对 n 比特的整数, 其运行时间为 $\exp((c + o(1)))n^{1/3} \log^{2/3} n$, 这里 $c < 2$. 对 RSA, 费时长于这个时间

界的攻击是没有兴趣的. 这些攻击包括穷尽搜索 M 及 RSA 刚发表不久出现的老一些的攻击方法.

我们综述的是不直接分解 RSA 模 N 而解密消息的方法. 但值得注意的是当 RSA 模 $N = pq$ 落于的一个稀疏的子集, N 易于被分解. 例如, 若 $p-1$ 的素因子小于 B , N 能在少于 B^3 的时间内被分解. 一些使用明确舍弃 $p-1$ 是小素数乘积的素数 p .

如上面所表示, 若存在有效的分解算法, 那么 RSA 是不安全的. 其反面是一个长期没有解决的问题: 为有效计算 $\bmod N$ 的 e 次方根, 一定要分解 N 吗? 攻破 RSA 与分解一样难吗? 我们具体叙述问题如下:

公开问题 1: 给定满足 $\gcd(e, \varphi(N)) = 1$ 的整数 N 和 e , 定义函数 $f_{e,N}: Z_N^* \rightarrow Z_N^*$, 这里 $f_{e,N}(x) = x^{1/e} \bmod N$. 给定 N 和某个 e 的预言 $f_{e,N}(x)$, 存在分解 N 的多项式时间算法 A 吗?

对 $f(x)$ 的一个预言指对任何输入 x , 在单位时间内计算 $f(x)$ 的值. 最近, Boneh 和 Venkatesan 提供的证据表明: 对小的 e 上面问题的答案可能是“不”. 换言之, 对小的 e 可能不存在多项式时间的从因子分解到攻破 RSA 的约化. 为证明这一点, 他们证明, 在某特定模型中, 对 e 小的时候的肯定回答会产生有效因子分解的算法. 我们注意到对公开问题 1 的肯定回答引起对 RSA 的选择密文攻击. 所以, 否定的回答可能是受欢迎的.

其次, 我们证明攻击私钥 d 与分解 N 是等价的. 因此对知道 d 的一方, 没有必要隐瞒 N 的分解.

事实 1. 设 (N, e) 是一 RSA 公钥. 给定私钥 d , 可有效地分解模 $N = pq$. 反之, 给定 N 的分解, 可有效地恢复 d .

证明: 由 N 的分解得出 $\varphi(N)$, 由于 e 已知, 因此可以恢复 d . 这就证明了逆断言. 我们现证, 对给定的 d , 可以分解 N . 对 d , 计算 $k = de - 1$. 由 d 及 e 的定义可知 k 是 $\varphi(N)$ 的倍数. 由于 $\varphi(N)$ 为偶数, 设 $k = 2^t r$, 这里 r 为奇数, $t \geq 1$. 对任何 $g \in Z_N^*$, 有 $g^k = 1$, 所以 $g^{k/2}$ 是单位元模 N 的平方根. 由中国剩余定理 (Chinese Remainder Theorem, 简记 CRT), 1 模 $N = pq$ 有四个平方根. 两个平方根为 ± 1 , 另外两个为 $\pm x$, x 满足 $x = 1 \bmod p$ 及 $x = -1 \bmod q$. 利用后两个平方根中任何一个, 计算 $\gcd(x-1, N)$ 可得到 N 的分解. 一个直接的讨论指出若 g 从 Z_N^* 中随机选择, 序列 $g^{k/2}, g^{k/4}, \dots, g^{k/2^t} \bmod N$ 中的元素是单位的平方根的概率 (对所选的 g) 至少为 $1/2$. 序列中的所有元素可在 $O(n^3)$ 的时间界内有效地算出, 此处 $n = \log_2 N$.

3 基本攻击

我们来描述一些早期的基本攻击. 这些攻击说明了对 RSA 的明显误用. 尽管这样的攻击有许多, 我们仅给两个例子.

3.1 共模攻击

为避免对每个用户生成一个不同的模 $N = pq$, 也许希望 N 一旦固定就由所有的用

户使用同一个 N 。一可信的中心机构可对用户 i 提供唯一的一对 e_i, d_i 。用户 i 由此形成公钥 $\langle N, e_i \rangle$ 和保密钥 $\langle N, d_i \rangle$ 。

初看起来这没有什么问题, 给 Alice 的一份密文 $C = M^{e_a} \bmod N$ 不会被 Bob 解密, 因为 Bob 没有 d_a 。然而, 这并不正确, 结果导致系统是不安全的。由事实 1, Bob 可用他自己的指数 e_b, d_b 分解模 N 。一旦被分解, Bob 可以从 Alice 的公钥 e_a 恢复她的私钥 d_a 。这一结果属于 Simmons, 这说明—RSA 模永远不应为超过一个以上的用户使用。

3.2 致盲攻击

设 $\langle N, d \rangle$ 为 Bob 的私钥, $\langle N, e \rangle$ 为他对应的公钥。假设 Marvin 想使 Bob 在消息 $M \in Z_N^*$ 上签字。Bob 不是傻子, 所以他拒绝对 M 签字。Marvin 可用下法: 他随机选择 $r \in Z_N^*$ 并置 $M' = r^e M \bmod N$ 。然后他要求 Bob 对随机消息 M' 签字。Bob 可能会对看起来无害的消息 M' 签上他的字 S' 。忆及 $S' = (M')^d \bmod N$ 。现在 Marvin 简单地计算 $S = S'/r \bmod N$, 从而得到 Bob 对原始 M 的签字 S 。事实上,

$$S^e = (S')^e / r^e = (M')^{ed} / r^e \equiv M' / r^e = M \pmod{N}.$$

这一技巧, 称为致盲, 使 Marvin 能通过要求 Bob 给一随机的“致盲”消息签字, 从而得到 Bob 对一消息的有效签字。Bob 不知道他实际签字的消息的任何信息。由于绝大多数签名方案在签字前应用一单向 hash 函数于消息 M , 这种攻击不是一件严重的事情。尽管我们提出致盲作为一种攻击方法, 它实际上对 RSA 实现匿名数字货币 (货币可用来购物, 但不暴露购物者的身份) 是一个有用的性质。

4 低私人指数攻击

为减少加密时间 (或生成签名的时间), 用户可能希望用数值小的 d 而不是随机的 d 。因为模指数运算所用时间是 $\log_2 d$ 的线性函数, 小的 d 可至少在执行速度上提高 10 倍 (对 1024 比特的模)。不幸的是, 对小的 d , 一种由 M.Wiener 提出的巧妙的攻击证明, 可完全攻破相应的 RSA 密码系统。

定理 2 (M.Wiener) 设 $N = pq$ 且 $q < p < 2q$, 并设 $d < \frac{1}{3}N^{1/4}$ 。给定 $\langle N, e \rangle$, $ed = 1 \bmod \varphi(N)$, 则 Marvin 可有效地恢复 d 。

证明 证明基于使用连分数逼近。因 $ed = 1 \bmod \varphi(N)$, 存在 k 使得 $ed - k\varphi(N) = 1$, 所以,

$$\left| \frac{e}{\varphi(N)} - \frac{k}{d} \right| = \frac{1}{d\varphi(N)}.$$

因此 $\frac{k}{d}$ 是 $\frac{e}{\varphi(N)}$ 的一个近似。尽管 Marvin 不知道 $\varphi(N)$, 他不妨用 N 逼近它。事实上, 因为 $\varphi(N) = N - p - q + 1$, $p + q - 1 < 3\sqrt{N}$, 我们有 $|N - \varphi(N)| < 3\sqrt{N}$ 。在出现 $\varphi(N)$

*校者注: 在密码学中存在预言者给出部分信息, 在此前提下解密。预言者给出信息的时间可忽略。

的地方用 N 来代替, 我们得到:

$$\begin{aligned} \left| \frac{e}{N} - \frac{k}{d} \right| &= \left| \frac{ed - k\varphi(N) - kN + k\varphi(N)}{Nd} \right| \\ &= \left| \frac{1 - k(N - \varphi(N))}{Nd} \right| \leq \left| \frac{3k\sqrt{N}}{Nd} \right| \\ &= \frac{3k}{d\sqrt{N}}. \end{aligned}$$

我们有 $k\varphi(N) = ed - 1 < ed$. 因 $e < \varphi(N)$, 我们看到 $k < d < \frac{1}{3}N^{1/4}$. 因此我们得到:

$$\left| \frac{e}{N} - \frac{k}{d} \right| \leq \frac{1}{d\sqrt{N}} < \frac{1}{2d^2}$$

这是一个经典的逼近关系. 与 e/N 如此接近的逼近分数 $k/d (d < N)$ 的数目由 $\log_2 N$ 界定. 事实上, 所有这些分数可以通过 e/N 的连分数展开的收敛项而得到. 所有要做的就是计算 $\log N$ 个 e/N 的连分数的收敛项. 它们中的一个将等于 k/d . 因 $ed - k\varphi(N) = 1$, 我们有 $\gcd(k, d) = 1$, 因此 k/d 是既约分数. 这是一个恢复保密钥 d 的线性时间算法.

因典型的 N 是 1024 比特, 由此 d 至少是 256 比特长以避免这种攻击. 这对诸如“智能卡”之类的低能量装置是很不幸的, 因小的 d 才能得到大的储存. 然而并非全盘皆输. Wiener 描述了一些既可以快速解密又不受这种攻击影响的方法:

大的 e 假设用 $\langle N, e' \rangle$ 作公钥而代替减小 e , 这里 $e' = e + t\varphi(N)$, 对某个大的 t . 很清楚 e' 可用来代替 e 给消息加密. 然而, 用大的 e 时, 在以上证明中 k 的值不会小. 简单的计算表明若 $e' > N^{1.5}$, 无论 d 多小, 以上的攻击不再奏效. 但不幸的是, 大的 e 增加加密时间.

用 CRT: 另一选择是用中国剩余定理 (CRT). 假设选择 d 既满足 $d_p = d \bmod (p-1)$, 又满足 $d_q = d \bmod (q-1)$, d_p, d_q 较小, 比如说每个是 128 比特. 对密文 C 的快速解密可如下进行: 首先计算 $M_p = C^{d_p} \bmod p$ 及 $M_q = C^{d_q} \bmod q$. 然而用 CRT 计算唯一的 $M \in Z_N$, M 满足: $M = M_p \bmod p$, 且 $M = M_q \bmod q$. 得到的 M 满足要求, $M = C^d \bmod N$. 要点是尽管 d_p 和 d_q 的值较小, $d \bmod \varphi(N)$ 可以很大, 即与 $\varphi(N)$ 同阶. 结果是, 定理 2 的攻击不能被应用. 我们注意到若 $\langle N, e \rangle$ 给定, 存在一种攻击, 使攻击者在 $O(\min(\sqrt{d_p}, \sqrt{d_q}))$ 的时间界内分解 N . 因此 d_p 和 d_q 不能太小.

我们不知道这两种方法中的任何一个是否安全. 我们所知道的只是 Wiener 的攻击对它们无效. 定理 2 最近由 Boneh 和 Durfee 改进, 他们证明, 只要 $d < N^{0.292}$, 攻击者可从 $\langle N, e \rangle$ 有效地恢复 d . 这些结果表明 Wiener 的界不是紧的. 似乎正确的界为 $d < N^{0.5}$. 在此文写作时, 这是一个公开问题.

公开问题 2 设 $N = pq$ 且 $d < N^{0.5}$. 若 Marvin 知道 $\langle N, e \rangle$ 且 $ed = 1 \bmod \varphi(N)$, $e < \varphi(N)$. 他能有效地恢复 d 吗?

5 低公开指数

为减少加密或签名验证的时间, 常用小的公开指数 e . e 的最小可能值为 3, 但为了对抗某种攻击, $e = 2^{16} + 1 = 65537$ 被推荐使用. 当用 $2^{16} + 1$ 时, 签名验证需 17 次乘法, 与之形成对比的是随机选取 $e \leq \varphi(N)$ 大约要作 1000 次乘法. 与前节的攻击不同, 对小 e 值的攻击远不是完全攻破.

5.1 Coppersmith 定理

对低公开指数 RSA 的最强有力的攻击基于 Coppersmith 的一个定理. Coppersmith 定理有许多应用, 这里只提到其中一些. 其证明要用 LLL 的格基约化算法, 解释如下.

定理 3 (Coppersmith) 设 N 为一整数, $f \in Z[x]$ 为一次数为 d 的首 1 多项式. 令 $X = N^{\frac{1}{d} - \epsilon}$, $\epsilon \geq 0$. 那么, 给定 (N, f) , Marvin 能有效地找到所有满足 $f(x_0) \equiv 0 \pmod{N}$ 且 $|x_0| \leq X$ 的整数 x_0 . 运行时间由用 LLL 算法于一 $O(w)$ 维的格上所用的时间控制, 这里 $w = \min\{1/\epsilon, \log_2 N\}$.

该定理提供了求 $f \pmod{N}$ 的所有小于 $X = N^{1/d}$ 的根的有效算法. 当 X 减小时算法的运行时间随之下降. 该定理的力量在于能找到模一合数 N 的多项式的小的根. 如果模为一素数, 则没有理由用 Coppersmith 定理, 因为存在更好的求根算法. 我们描述证明 Coppersmith 定理的主要思路. 我们遵从 Howgrave-Graham 的一个简化了的方法. 给定一多项式 $h(x) = \sum a_i x^i \in Z[x]$, 定义 $\|h\| = \sum |a_i|^2$. 证明基于如下观察.

引理 4 设 $h(x) \in Z[x]$ 为一 d 次多项式, X 为一正整数. 假设 $\|h(xX)\| < N/\sqrt{d}$. 若 $|x_0| < X$ 满足 $h(x_0) \equiv 0 \pmod{N}$, 则 $h(x_0) = 0$ 在整数上成立.

证明: 由 Schwarz 不等式

$$\begin{aligned} |h(x_0)| &= \left| \sum a_i x_0^i \right| = \left| \sum a_i X^i \left(\frac{x_0}{X} \right)^i \right| \leq \sum \left| a_i X^i \left(\frac{x_0}{X} \right)^i \right| \\ &\leq \sum |a_i X^i| \leq \sqrt{d} \|h(xX)\| < N. \end{aligned}$$

因为 $h(x_0) \equiv 0 \pmod{N}$, 我们得出 $h(x_0) = 0$.

引理说明若 h 是一低范数的多项式, 则所有 $h \pmod{N}$ 的小根同时也是 h 在整数上的根. 为求 $f(x) \pmod{N}$ 的小根 x_0 , 引理提示应该寻找另一具有小范数的多项式 $h \in Z[x]$. 它与 $f \pmod{N}$ 有相同的根, 那么 x_0 将是 h 在整数上的根. 它易于求到. 为此, 我们不妨求一多项式 $g \in Z[x]$ 使得 $h = gf$ 具有低范数, 即范数小于 N . 这等于找多项式 $f, xf, x^2f, \dots, x^r f$ 的整数线性组合使之具有低范数. 不幸的是, 具有小范数的非平凡的线性组合难于遇到.

Coppersmith 发现解决这一问题的一个技巧: 若 $f(x_0) \equiv 0 \pmod{N}$, 则对任意 k , $f(x_0)^k \equiv 0 \pmod{N^k}$. 更一般些, 对事先定义的 m , 定义多项式

$$g_{u,v}(x) = N^{m-u} x^u f(x)^v$$

那么对任意 $u \geq 0$ 和 $0 \leq v \leq m$, x_0 是 $g_{u,v}(x) \pmod{N^m}$ 的一根. 为应用引理 4, 我们必须找到多项式 $g_{u,v}(x)$ 的整数线性组合 $h(x)$ 使 $h(xX)$ 的范数小于 N^m (回忆 X 是 x_0 的

上界且满足 $X \leq N^{1/d}$ 。由于范数的上界是松驰的 (是 N^m 而不是 N)，可以证明对充分大的 m ，常存在一线性组合 $h(x)$ 满足界的要求。 $h(x)$ 一旦找到，引理 4 蕴含 x_0 是 $h(x)$ 在整数上的根。由此 x_0 易于计算。

剩下的是说明如何有效地找到 $h(x)$ 。为此，我们须先叙述关于 Z^w 中格的一些基本事实。我们推荐 L.Lovasz 的书 “An Algorithmic Theory of Number, Graphs and convexity, SIAM Publications, 1986” 为这一课题的简明导引。设 $u_1, \dots, u_w \in Z^w$ 为线性无关向量。由 $\langle u_1, \dots, u_w \rangle$ 张成的 (满秩) 格 L 是 $u_1, \dots, u_w$ 的整数线性组合的集合。 L 的行列式定义为一 $w \times w$ 方阵的行列式，该方阵的行是向量 $u_1, \dots, u_w$ 。

对我们的情形，我们视多项式 $g_{u,v}(xX)$ 为向量并研究由它们张成的格 L 。我们设 $v = 0, \dots, m$ ，以及 $u = 0, \dots, d-1$ ，则格 L 的维数 $w = d(m+1)$ 。例如，当 f 为二次首 1 多项式且 $m = 3$ 时，得到的格是由以下矩阵的行张成的格：

$$\begin{array}{l} g_{0,0}(xX) \\ g_{1,0}(xX) \\ g_{0,1}(xX) \\ g_{1,1}(xX) \\ g_{0,2}(xX) \\ g_{1,2}(xX) \\ g_{0,3}(xX) \\ g_{1,3}(xX) \end{array} \begin{bmatrix} 1 & x & x^2 & x^3 & x^4 & x^5 & x^6 & x^7 \\ N^3 & & & & & & & \\ & XN^3 & & & & & & \\ * & * & X^2N^2 & & & & & \\ & * & * & X^3N^2 & & & & \\ * & * & * & * & X^4N & & & \\ & * & * & * & * & X^5N & & \\ * & * & * & * & * & * & X^6 & \\ & * & * & * & * & * & * & X^7 \end{bmatrix}$$

我们忽略了标 * 的项对应多项式的系数。空白的地方是零。由于矩阵为三角阵，其行列式为对角线上元素的积 (上面已明确给出)。我们的目标是找到格中的短向量。

Hermite 的一个经典结果说任何 w 维的格 L 包含一非零点 $v \in L$ ，其 L_2 范数满足 $\|v\| \leq \gamma_w \det(L)^{1/w}$ ，此处 γ_w 为只与 w 有关的常数。Hermite 的界可用于我们的格，当 m 充分大时，格中包含要求的向量，其范数小于 N^m 。问题是我们能否有效地构造格 L 中的短向量，其长度不超过 Hermite 界。LLL 算法是可以精确做到这点的有效算法。

事实 5 (LLL) 设 L 是由 $\langle u_1, \dots, u_w \rangle$ 张成的格，当以 $\langle u_1, \dots, u_w \rangle$ 作为输入时，LLL 算法输出一向量 $v \in L$ 满足

$$\|v\| \leq 2^{w/4} \det(L)^{1/w}$$

LLL 的运行时间是输入长的二次式。

LLL 算法 (由它的发明者 L.Lovasz, A.Lenstra 及 H.Lenstra Jr. 得名) 在计算数论及密码学上有许多应用。发现于 1982 年的 LLL 算法提供了在整数上，更一般地，在数环上分解多项式的有效算法。LLL 经常用于攻击各种密码系统。例如，许多基于“背包问题”的密码系统已用 LLL 攻破。

用 LLL，我们可以完成 Coppersmith 定理的证明。为保证由 LLL 产生的向量满足引理 4 的界，我们需要

$$2^{w/4} \det(L)^{1/w} < N^w / \sqrt{\omega},$$

这里 $w = d(m+1)$ 是 L 的维数。常规计算表明对充分大的 m ，界是满足的。事实上，

当 $X = N^{\frac{1}{2}-\varepsilon}$, 只要取 $m = O(k/d)$, $k = \min(1/\varepsilon, \log N)$ 即可. 因此, 运算时间由 LLL 作用于维数为 $O(k)$ 的格上的时间所控制, 正如所求.

一个自然的问题是 Coppersmith 定理能否用于二元或多个变元的多项式. 若给定 $f(x, y) \in Z_N[x, y]$, 对 $|x_0 y_0|$ 的适当的界存在 $f(x, y)$ 的一根 (x_0, y_0) , Marvin 能有效地找到 (x_0, y_0) 吗? 尽管对一些二元多项式同样的技巧起作用, 但怎样证明这一点在目前是一个公开问题. 由于越来越多的结果依赖 Coppersmith 定理的二元推广, 一个严格的算法将是非常有用的.

公开问题 3 寻找一般性的条件, 在此条件下 Coppersmith 定理可推广到二元多项式.

5.2 Hastad 的广播攻击

作为 Coppersmith 定理的第一个应用, 我们提出 Hastad 对一个老的攻击的改进. 假设 Bob 想把消息 M 加密发给几个用户 $P_1, P_2, \dots, P_k$. 每一用户有自己的 RSA 钥 (N_i, e_i) . 我们假设 M 小于所有的 N_i . 自然地, 为发送 M , Bob 用每一个公钥加密然后把第 i 个密文发送给 P_i . Marvin 在 Bob 不知道的情况下窃听 Bob 的通信并收集这 k 个传送的密文.

为简单起见, 假设所有的公开指数 e_i 都等于 3. 一个简单的推理证明, 若 $k > 3$, Marvin 可以恢复 M . 事实上, Marvin 得到 C_1, C_2, C_3 , 这里

$$C_1 = M^3 \pmod{N_1}, \quad C_2 = M^3 \pmod{N_2}, \quad C_3 = M^3 \pmod{N_3}.$$

我们不妨假设对所有的 $i \neq j$, $\gcd(N_i, N_j) = 1$. 否则 Marvin 可分解某个 N_i . 应用中国剩余定理于 C_1, C_2, C_3 , 我们得出 $C' \in Z_{N_1 N_2 N_3}$ 且 $C' = M^3 \pmod{N_1 N_2 N_3}$. 因 M 小于所有 N_i , 我们有 $M^3 < N_1 N_2 N_3$. 这时 $C' = M^3$ 在整数上成立. 由此, Marvin 可以通过计算 C' 的实三次根来恢复 M . 更一般些, 若所有公开指数都等于 e , 一旦 $k \geq e$, Marvin 就能恢复 M . 这种攻击只在应用小的 e 时才有效.

Hastad 描述了一种更为强大的攻击. 为了导出 Hastad 的结果, 考虑一种对以上攻击的简单防御. 代替广播加密的 M , Bob 在加密前将消息填充. 例如, M 长 m 比特, Bob 给 P_i 发送 $M_i = i \cdot 2^m + M$. 由于 Marvin 得到的是不同消息的加密, 他不能实施上面的攻击. 不幸的是, Hastad 证明这种线性填充是不安全的. 事实上, 他证明在加密前用任何固定的多项式填充并不能阻止这种攻击.

假设对每个参与者 $P_1, P_2, \dots, P_k$, Bob 有一固定的公开多项式 $f_i \in Z_{N_i}[x]$. 为广播消息 M , Bob 发送加密的 $f_i(M)$ 给 P_i . 通过窃听, Marvin 得知 $C_i = f_i(M)^{e_i} \pmod{N_i}$, $i = 1, \dots, k$. Hastad 证明, 只要涉及的用户充分多, Marvin 可以从所有的密文中恢复明文 M . 以下定理是 Hastad 结果的一个加强形式.

定理 6 (Hastad) 设 $N_1, \dots, N_k$ 是两两互素的整数, 且 $N_{\min} = \min_i(N_i)$, 令 $g_i \in Z_{N_i}[x]$ 为 k 个多项式, 最大次为 d . 假设存在唯一的 $M < N_{\min}$ 对所用 $i = 1, \dots, k$ 满足 $g_i(M) = 0 \pmod{N_i}$. 在 $k > d$ 的假设下, 可以从 $(N_i, g_i)_{i=1}^k$ 中有效地恢复 M .

证明: 设 $\bar{N} = N_1 \cdots N_k$. 我们不妨假设所有 g_i 都是首 1 的. (事实上, 若对某个 i , g_i 的首项系数在 Z_N^* 中不可逆, 那么就暴露了 N_i 的因子分解.) 以 x 的适当幂次乘 g_i , 我们可以假定它们的次都为 d , 构造多项式

$$g(x) = \sum_{i=1}^k T_i g_i(x),$$

此处

$$T_i = \begin{cases} 1 \pmod{N_j} & \text{若 } i = j \\ 0 \pmod{N_j} & \text{若 } i \neq j \end{cases}.$$

诸 T_i 是整数, 被称为中国剩余系数. 由于对所有 N_i , $g(x) \pmod{N_i}$ 首 1, 因此 $g(x)$ 一定是首 1 的, 其次数为 d . 而且, 我们知道 $g(M) = 0 \pmod{\bar{N}}$, 因为 $M < N_{\min} \leq \bar{N}^{1/k} < \bar{N}^{1/d}$, 现在可由定理 3 得出定理 6.

该定理证明, 假设提供的方程充分多, 模互素整数的单变量方程组可有效求解. 设 $g_i = f_i^{e_i} - C_i \pmod{N_i}$, 我们知道只要用户的数目不小于 d , 则 Marvin 可从密文中恢复 M , 这里 d 是 $e_i \deg(f_i)$ 在 $i = 1, \dots, k$ 上的极大值. 特别地, 若所有 e_i 都等于 e 且 Bob 发送线性相关的信息, 那么当 $k > e$ 时, Marvin 可恢复明文.

Hastad 的原定理比上面叙述的要弱. Hastad 不是需要 d 个多项式, 而是 $d(d+1)/2$ 个多项式. Hastad 的证明类似于上节对 Coppersmith 定理的证明. 然而, Hastad 没有发挥格中 g 的作用, 因此他得到了较弱的界.

为结束本节, 我们指出为正确防御上面的广播攻击, 必须用随机填充而不是固定填充.

5.3 Franklin-Reiter 的相关消息攻击

Franklin 和 Reiter 发现了当 Bob 用相同的模给 Alice 发送相关的加密信息时的巧妙攻击. 设 (N, e) 为 Alice 的公钥. 假设 $M_1, M_2 \in Z_N^*$ 为满足 $M_1 = f(M_2) \pmod{N}$ 的两个不同消息, 这里的 $f \in Z_N[x]$ 为公开已知的多项式. 为发送 M_1 和 M_2 给 Alice, Bob 加密并发送得出的密文 C_1, C_2 . 我们证明给定 C_1, C_2 , Marvin 能很容易地恢复 M_1, M_2 . 尽管这种攻击对任何小的 e 奏效, 我们对 $e = 3$ 叙述以下引理以简化证明.

引理 7(FR) 设 $e = 3$, (N, e) 为 RSA 公钥, 设 $M_1 \neq M_2 \in Z_N^*$ 满足 $M_1 = f(M_2) \pmod{N}$, f 为线性多项式 $f = ax + b \in Z_N[x]$ 且 $b \neq 0$. 那么, 给定 (N, e, C_1, C_2, f) , Marvin 可在 $\log N$ 的二次式的时间内恢复 M_1, M_2 .

证明: 为保持这一部分证明的一般性, 在叙述中我们用一般的 e (而不是限制在 $e = 3$). 因为 $C_1 = M_1^e \pmod{N}$, 我们知道 M_2 是多项式 $g_1(x) = f(x)^e - C_1 \in Z_N[x]$ 的根, 类似地, M_2 是 $g_2(x) = X^e - C_2 \in Z_N[x]$ 的根, 线性因子 $x - M_2$ 整除两个多项式. 因此, Marvin 可以用 Euclid 算法求 g_1 和 g_2 的 gcd. 若得出的 gcd 是线性的, 就找到了 M_2 . gcd 可以在 e 和 $\log N$ 的二次式的时间内求得.

当 $e = 3$ 时, 我们证明 gcd 一定是线性的. 多项式 $X^3 - C_2$ 在模 p 和 q 上分解为一线性因子和一二二次不可约因子 (回忆 $\gcd(e, \varphi(N)) = 1$, 因此 $X^3 - C_2$ 在 Z_N 中只有一个

根). 因 g_2 不能整除 g_1 , 因此 gcd 一定是线性的. 对 $e > 3$, gcd 差不多总是线性的. 然而, 对极少的 M_1, M_2 和 f , 可能得到非线性 gcd, 在此时攻击失败.

对 $e > 3$, 攻击所占的时间是 e 的二次式. 因此, 它只能用于小公开指数的情形. 对大的 e 计算 gcd 是不可行的. 设计对任意 e 的攻击是一个有趣的 (尽管可能是困难的) 问题. 特别地, 上面的 g_1 和 g_2 的 gcd 可以在 $\log e$ 的多项式时间内求出吗?

5.4 Coppersmith 的短填充攻击

Franklin-Reiter 的攻击看起来可能有点人为. 总之, 为什么 Bob 要向 Alice 发送相关消息的加密呢? Coppersmith 改进了以上攻击并证明了关于填充的一个重要结果.

一种简单的随机算法是在明文 M 的后面附上随机的几个比特, 下面的攻击揭示了这种简单填充的危险. 假设 Bob 发送正常填充加密的 M 给 Alice, Marvin 截获密文并阻止它到达目的地. Bob 注意到 Alice 对他的消息没有回应并决定重发 M 给 Alice, 他随机填充 M 然后传送所得到的密文. Marvin 现在有同一消息用两种不同的随机填充后加密所对应的密文. 下面定理表明, 尽管 Marvin 不知道所用的填充, 他能恢复明文.

定理 8 设 (N, e) 是 RSA 公钥, 这里 N 长 n 比特, 令 $m = \lceil n/e^2 \rceil$. 设 $M \in Z_N^*$ 是一长至多为 $n - m$ 比特的消息. 定义 $M_1 = 2^m M + r_1$ 和 $M_2 = 2^m M + r_2$, 这里 r_1 和 r_2 是满足 $0 < r_1, r_2 < 2^m$ 的不同整数. 若给 Marvin (N, e) 以及 M_1, M_2 的加密 C_1, C_2 (但不给 r_1 及 r_2), 他能有效地恢复 M .

证明: 定义 $g_1(x, y) = x^e - C_1, g_2(x, y) = (x + y)^e - C_2$, 我们知道当 $y = r_2 - r_1$ 时, 这些多项式以 M_1 为一公共根. 换言之, $\Delta = r_2 - r_1$ 是“结式” $h(y) = \text{res}_x(g_1, g_2) \in Z_N[y]$ 的根. h 的次数至多为 e^2 , 而且 $|\Delta| < 2^m < N^{1/e^2}$. 因此, Δ 是 $h \bmod N$ 的一个小根, Marvin 可用 Coppersmith 定理 (定理 3) 有效地找到它. 一旦 Δ 已知, 前节的 Franklin-Reiter 攻击可用来恢复 M_2 , 然后恢复 M .

$e = 3$ 时, 当填充的长度小于消息长度的 $1/9$ 时, 可用该法攻击. 这是一个重要的结果. 注意对推荐的 $e = 65537$, 该攻击对具标准规模的模是无用的.

5.5 部分钥暴露攻击

设 (N, d) 为 RSA 私钥. 假设 Marvin 通过一些途径可暴露 d 的一部分比特, 比如, d 的 $1/4$ 比特. 他能重构 d 的其余部分吗? 令人吃惊的是, 当对应的公钥小时, 答案是肯定的. 最近, Boneh, Durfee 和 Frankel 证明当 $e < \sqrt{N}$ 时, 从 d 的一部分比特可重构全部 d . 这些结果显示了保护整个 RSA 私钥的重要性.

定理 9 (BDF) 设 (N, d) 是 RSA 私钥, N 长为 n 比特. 给定 d 的低位 $\lceil n/4 \rceil$ 比特, Marvin 可在 $e \log_2 e$ 的线性时间内恢复 d .

证明依赖于 Coppersmith 的另一个美妙定理.

定理 10 (Coppersmith) 设 $N = pq$ 是一 n 比特的 RSA 模, 给定 p 的 $n/4$ 高位比特或低位比特, 则可以有效地分解 N .

从定理 10 易得定理 9. 事实上, 由 e 和 d 的定义, 存在一整数 k 使得

$$ed - k(N - p - q + 1) = 1.$$

由 $d < \varphi(N)$, 我们必定有 $0 < k \leq e$. 把以上方程模 $2^{n/4}$ 并置 $q = N/p$, 得

$$(ed)p - kp(N - p + 1) + kN = p \pmod{2^{n/4}}.$$

由于 Marvin 已有 d 的 $1/4$ 低位比特, 他知道 $ed \pmod{2^{n/4}}$ 的值. 因此, 他得到一个关于 k 与 p 的方程. 对于 k 的 e 个可能值, Marvin 解 p 的二次方程并得到 $p \pmod{2^{n/4}}$ 的候选值. 对每个这样的候选值, 他用定理 10 的算法试图分解 N . 可以证明 $p \pmod{2^{n/4}}$ 的全部候选值至多为 $e \log_2 e$ 个. 因此, 他至多试 $e \log_2 e$ 次, 就可以有效地分解 N .

定理 9 被称为部分钥暴露攻击. 对较大但小于 $\sqrt{N}$ 的 e , 存在类似的攻击. 然而, 其技巧有些复杂. 有趣的是基于离散对数的密码系统, 如 El-Gamal 公钥系统, 似乎不受部分钥暴露的影响. 事实上, 若已知 $g^x \pmod{p}$ 及 x 的一部分比特, 还不存在已知的多项式时间算法去计算 x 的其余部分.

为结束本节, 我们证明当加密指数 e 小时, RSA 系统泄漏对应的私钥的从高位起的一半比特. 为此, 对整数 $0 < k \leq e$ 再次考虑方程 $ed - k(N - p - q + 1) = 1$. 给定 k , Marvin 容易计算

$$\hat{d} = [(kN + 1)/e].$$

那么

$$|\hat{d} - d| \leq k(p + q)/e \leq 3k\sqrt{N}/e < 3\sqrt{N}.$$

因此 $\hat{d}$ 是 d 的一个良好逼近. 逼近的界表明, 对大多数 d , $\hat{d}$ 从最高位起的一半与 d 的从最高位起的一半相等. 因 k 只有 e 个可能值, Marvin 可构造规模为 e 的小集合, 使该集中某一元素等于 d 从最高位起的一半比特. $e = 3$ 的情形特别有趣. 在此时可以证明 $k = 2$, 因此系统完全地泄露 d 的从最高位起的一半比特.

6 使用攻击

我们把注意力转到一类完全不同的攻击. 这些攻击把焦点集中在 RSA 的使用上, 而不是 RSA 函数隐含的结构上.

6.1 时间攻击

考虑一储有 RSA 私钥的智能卡. 由于该卡抗篡改, Marvin 也许不能检验卡的内容并暴露私钥. 然而, 一种归功于 Kocher 的巧妙攻击证明, 通过精确测量智能卡执行 RSA 解密 (或签名) 的时间, Marvin 可很快发现私人解密指数 d .

我们说明怎样用“重复平方算法”实施对简单应用 RSA 的攻击. 设 $d = d_n d_{n-1} \cdots d_0$ 是 d 的二进制表示. (即 $d = \sum_{i=0}^n 2^i d_i, d_i \in \{0, 1\}$). 重复平方算法, 通过至多 $2n$ 次模乘, 计算 $C = M^d \pmod{N}$, 它基于观察 $C = \prod_{i=0}^n M^{2^i d_i} \pmod{N}$. 算法如下:

设 z 等于 M , 及 C 等于 1. 对 $i = 0, \dots, n$, 做下列各步:

1. 若 $d_i = 1$, 置 C 等于 $Cz \bmod N$.

2. 置 z 等于 $z^2 \bmod N$.

最后, C 的值为 $M^d \bmod N$.

变量 z 通过 $M^{2^i} \bmod N$, ($i = 0, \dots, n$) 的值的集合, 变量 C “收集” 集合中适当的幂以得到 $M^d \bmod N$.

为实施攻击, Marvin 要求智能卡为大量随机消息 $M_1, \dots, M_k \in Z_N^*$ 生成签名, 并测定生成每个签名的时间 T_i .

攻击从最低位开始, 每次恢复 d 的一个比特. 我们知道 d 为奇数, 于是 $d_0 = 1$. 考虑第二次循环. 初始置 $z = M^2 \bmod N$, 及 $C = M$. 若 $d_1 = 1$, 则智能卡计算乘积 $Cz = M \cdot M^2 \bmod N$, 否则, 它不计算. 设 t_i 是智能卡计算 $M_i \cdot M_i^2 \bmod N$ 所用的时间. t_i 各不相同, 因计算 $M_i \cdot M_i^2 \bmod N$ 所用时间依赖 M_i 的值 (简单的模约化算法所用时间依赖于被约化的值). Marvin 一旦获得卡的物理特性, (在实施攻击前) 他测量 t_i 的时间列.

Kocher 观察到当 $d_1 = 1$ 时, 两个列 $\{t_i\}$ 和 $\{T_i\}$ 是相关的. 例如, 对某个 i , t_i 比期望值大得多, 那么 T_i 很可能也比其期望值大得多. 另一方面, 当 $d_1 = 0$ 时, $\{t_i\}$ 和 $\{T_i\}$ 表现为独立的随机变量. 通过测量相关性, Marvin 可确定 d_1 是 1 或 0. 继续这一过程, 他可以恢复 d_2, d_3 等等. 注意若用低公开指数 e , 上节的部分钥暴露攻击证明 Kocher 的时间攻击只需用到发现 d 的 $1/4$ 比特.

有两种方法可抵御这种攻击. 最简单的是增加适当的延迟使模指数运算所用的时间都为一固定值. 第二种方法, 属于 Rivest, 是基于致盲的. 在智能卡给 M 加密之前随机选取 $r \in Z_N^*$ 并计算 $M' = M \cdot r^e \bmod N$. 应用 d 于 M' 得到 $C' = (M')^d \bmod N$. 最后, 智能卡置 $C = C'/r \bmod N$. 用这种方法, 智能卡应用 d 于一个 Marvin 不知道的随机消息 M' . 结果, Marvin 无法实施攻击.

沿这条路线 Kocher 最近发现了另一种称为能量密码分析的攻击. Kocher 证明通过精确测定智能卡在生成签名时的能量消耗量(power consumption), Marvin 常能发现保密钥. 这由于, 卡在进行多精度乘法运算时电力消耗高于常时. 通过测量高消耗周期, Marvin 很容易发现在一给定时间内卡执行了一或两次乘积, 从而暴露 d 的比特.

6.2 随机错误

应用 RSA 加密或签名时为加快计算 $M^d \bmod N$ 的速度经常用中国剩余定理, 代替在 $\bmod N$ 下的计算. Bob 首先计算模 p 和模 q 的签名, 然后用中国剩余定理把结果组合起来. 更精确的, Bob 首先计算

$$C_p = M^{d_p} \bmod p \text{ 及 } C_q = M^{d_q} \bmod q,$$

这里 $d_p = d \bmod (p-1)$, $d_q = d \bmod (q-1)$. 通过置

$$C = T_1 C_p + T_2 C_q \bmod N,$$

他得到签名 C , 这里

$$T_1 = \begin{Bmatrix} 1 & \text{mod } p \\ 0 & \text{mod } q \end{Bmatrix} \text{ 及 } T_2 = \begin{Bmatrix} 0 & \text{mod } p \\ 1 & \text{mod } q \end{Bmatrix}.$$

与两个指数运算相比, CRT 最后一步的运行时间可以忽略. 注意到 p 和 q 是 N 长度的一半. 因乘法的简单实现要用平方次的时间, 模 p 的乘法比模 N 的乘法快 4 倍. 而且, d_p 是 d 长度的一半, 因此计算 $M^{d_p} \text{ mod } p$ 比计算 $M^d \text{ mod } N$ 快 8 倍. 总的签名时间因此被降低了 4 倍. 许多使用由此法得以改进.

Boneh, DeMillo 和 Lipton 观察到 CRT 的使用有内在的危险. 假设在产生一个签名时, Bob 的计算机上的一个错误 (glitch) 引起在单个指令下的错误计算. 例如, 当从一个位置向另一位置拷贝记录时, 丢失了 1 比特 (错误可能由周围的电磁干扰或罕见的硬件臭虫——如在 Pentium 芯片的早期版本中出现的——所引起). 给定一个无效签名, Marvin 能容易地分解 Bob 所用的模 N .

对这种攻击, 我们采用 A.K.Lenstra 的表述. 假设 Bob 在生成签名时发生了一个错误, 结果是 C_p 和 C_q 中刚好有一个计算不正确. 比如说 C_p 正确, 但 $\hat{C}_q$ 不正确, 签名结果是 $\hat{C} = T_1 C_p + T_2 \hat{C}_q$. 一旦 Marvin 接到 $\hat{C}$, 由于 $\hat{C}^e \neq M \text{ mod } N$, 因此他知道这不是一个正确签名. 然而, 注意到

$$\hat{C}^e = M \text{ mod } p \text{ 而 } M \text{ mod } q.$$

因此, $\gcd(N, \hat{C}^e - M)$ 暴露了 N 的非平凡因子.

为使攻击起作用, Marvin 必须具有 M 的全部知识: 即我们假设 Bob 没有利用随机填充. 签名前的随机填充可抵御这种攻击. 更简单的防御是 Bob 在发出签名前对它进行检验. 检验在用 CRT 方法加速之后特别重要. 随机错误对许多密码系统是危险的. 许多系统, 包括不用 CRT 实现的 RSA, 可用随机错误攻击. 然而, 这些结果更多是理论上的.

6.3 Bleichenbacher 对 PKCS1 攻击的方法

设 N 为 n -比特的 RSA 模, M 为 m 比特的消息且 $m < n$. 在应用 RSA 加密之前自然要在 M 后填充随机比特使它达到 n 比特, 公钥密码标准 1 (PKCS1) 的一个早期版本用这种方法. 填充后, 信息看起来如下:

02 随机 00 M

现在消息长 n 比特并直接用 RSA 加密. 起始的一块长 16 比特并包含 02, 它用来指示有一随机填充增加到消息上.

当 Bob 的机器接到 PKCS1 消息时, 一应用程序 (例如, 万维网浏览器) 对它进行解密, 检查起始的一块, 并甩掉随机填充. 但是, 一些应用程序检查 “02” 初始块, 并且若无这样的块, 它们就返还一个说 “无效密文” 的错误消息. Bleichenbacher 证明这一错误消息可导致灾难性的后果: 使用这一错误, Marvin 可解密他选择的密文.

(下转 287 页)